

Podcast 09 — Network Security

Podcast 09 — Network Security

Length target: 15 min **Repo references:** `domain-1-organizational/15-aws-network-firewall.md`, `16-aws-firewall-manager.md`, `33-waf.md`, `34-shield.md`, `43-pentest.md`

Topic & Scope

Layer-by-layer network defense: WAF (HTTP layer), Shield (DDoS), Network Firewall (VPC layer), Firewall Manager (org-wide policy). Plus pentest rules of engagement.

Service Coverage Depth

Deep: - AWS WAF — managed rules, custom rules, rate-based, ACLs on CloudFront / ALB / API GW / AppSync / Cognito - AWS Shield Standard vs Advanced — DDoS protection - AWS Network Firewall — stateful VPC firewall, Suricata rules - Firewall Manager — central enforcement across Org

Brief: - AWS Pentest rules of engagement (what's allowed without prior approval)

Structured Outline

1. **Open (30s)** — “Defense in layers: WAF at the HTTP edge, Shield against DDoS, Network Firewall at the VPC, Firewall Manager for org-wide policy.”
2. **WAF (4 min)** — Web ACLs, attached to CloudFront / ALB / API GW / AppSync / Cognito User Pool / App Runner, managed rule groups (AWSManagedRulesCommonRuleSet, OWASP), rate-based rules, JSON/XML body inspection
3. **Shield (3 min)** — Standard (free, layer 3/4 always on) vs Advanced (\$3k/mo, 24/7 DRT response, cost protection)
4. **Network Firewall (3 min)** — Suricata-compatible stateful firewall at VPC level, IDS/IPS, allow/deny by domain, deployment patterns (centralized via TGW)
5. **Firewall Manager (2 min)** — central WAF / Shield / Network Firewall / SG policy enforcement across Org
6. **Pentest Rules (1 min)** — 8 services pre-approved without permission (EC2, NAT GW, ELB, RDS, Aurora, CloudFront, API GW, Lightsail, Beanstalk)
7. **Rapid-Fire Trap Drill (60s)**

Must-Mention Exam Tips

- WAF protects: CloudFront, ALB, API Gateway, AppSync, Cognito User Pool, App Runner, Verified Access (HTTP layer)
- WAF managed rule groups: AWSManagedRulesCommonRuleSet, OWASP top 10, IP reputation, bot control, account takeover

- Rate-based rules: limit requests per 5-min window per source IP
- WAF inspects: headers, body (up to 64 KB by default, can be raised), URI, query strings, JSON/XML
- Shield Standard: free, always on, layer 3/4 DDoS protection
- Shield Advanced: \$3,000/month, 24/7 DDoS Response Team (DRT), cost protection on EC2/ELB/CloudFront/Route 53/Global Accelerator, attack diagnostics, integrates with WAF
- Network Firewall: stateful at VPC, Suricata rules, domain filtering, TLS inspection, deploy via Transit Gateway for centralized inspection
- Firewall Manager: requires Organizations + Config + admin account, enforces WAF / Shield Adv / Network Firewall / SG baseline across all accounts
- Pentest allowed without permission on 8 services; request approval for simulated events with higher impact

Must-Mention Exam Traps

- EXAM TRAP: WAF is HTTP layer — doesn't protect TCP/UDP non-HTTP traffic
- EXAM TRAP: WAF can't attach to NLB or EC2 directly — only to CloudFront / ALB / API GW / AppSync / Cognito / App Runner / Verified Access
- EXAM TRAP: Shield Standard is FREE and always on — questions asking for "free DDoS protection" → Standard
- EXAM TRAP: Shield Advanced's cost protection only kicks in if you contact AWS during the attack
- EXAM TRAP: Network Firewall is at VPC level (subnet routes redirected through firewall endpoints) — not a SG replacement
- EXAM TRAP: Firewall Manager requires AWS Organizations + Config enabled
- EXAM TRAP: Pentest of social engineering, DNS zone walking, or against AWS infrastructure is NOT allowed
- EXAM TRAP: SG + NACL + WAF + Network Firewall ALL stack — each layer is independent
- EXAM TRAP: WAF rate-based rule is per source IP, per 5-min — not per second
- EXAM TRAP: Body inspection in WAF defaults to 64 KB — large bodies bypass without explicit config
- EXAM TRAP: Shield Advanced response team is reactive — you must engage them, they don't auto-mitigate everything

Key Decision Matrix

Threat / Need	Pick
SQL injection, XSS, OWASP top 10	WAF managed rules
DDoS protection (free)	Shield Standard (always on)
Advanced DDoS + 24/7 response + cost protection	Shield Advanced
Block bots / scrapers	WAF Bot Control

Threat / Need	Pick
Egress filtering by domain from VPC	Network Firewall
Stateful IDS/IPS in VPC	Network Firewall
Enforce WAF policy across all accounts	Firewall Manager
Rate-limit suspicious IPs	WAF rate-based rule
Centralized inspection across many VPCs	Network Firewall via TGW

Tone & Style

- Layer-cake metaphor: edge → DDoS → VPC → Org policy
- Emphasize Shield Standard is FREE and protects everyone always
- Explicitly call out “\$3,000/month” cost of Shield Advanced

Rapid-Fire Closer

“WAF on NLB?” — “NO, WAF is HTTP-layer.” “Shield Standard cost?” — “FREE.” “Shield Advanced cost?” — “\$3,000/month.” “Stateful VPC firewall?” — “Network Firewall.” “Org-wide enforcement?” — “Firewall Manager.”